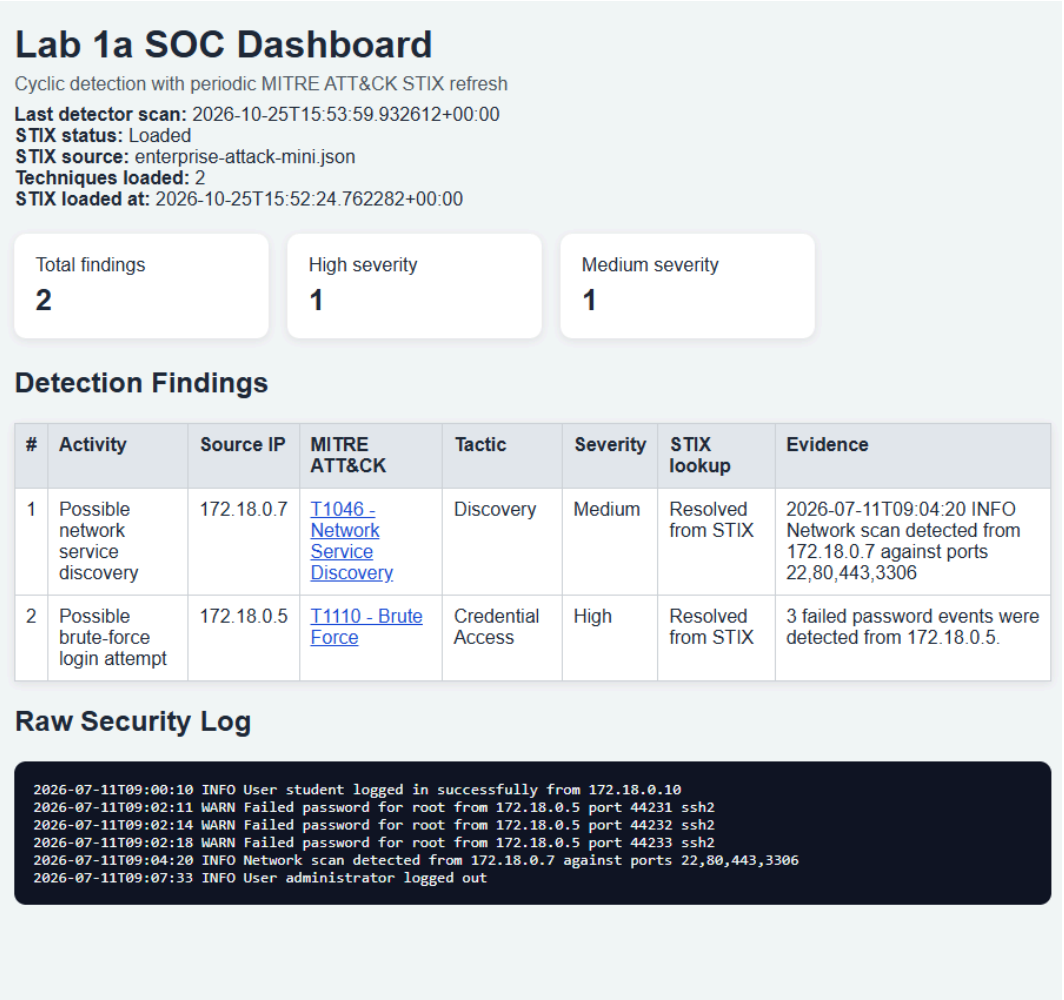
דוח מסכם – מעבדה 1a: זיהוי מבוסס חוקים ולוח בקרה SOC

1. אימות סביבת Docker וצילום מסך של לוח הבקרה (Dashboard)

סביבת המעבדה הוקמה בהצלחה באמצעות Docker Compose על פי ההנחיות. רכיבי המערכת שהופעלו כוללים את מנוע הזיהוי (`detector`), לוח הבקרה המקומי (`dashboard`) ורכיב הסימולטור האופציונלי (`simulator`).

- **הקמת השירותים:** בוצעה באמצעות הפקודה: `docker compose up --build -d`
- **אימות סטטוס הקונטיינרים:** בוצע באמצעות הפקודה: `docker compose ps` שני השירותים המרכזיים (detector ו-dashboard) עלו בהצלחה למצב פעיל (Up).
- **אימות קובץ הבסיס (Baseline):** לפני תחילת הניסויים אומת קובץ הלוג `logs/security.log`. הקובץ הכיל בדיוק 6 שורות נקיות, ונוצר ממנו עותק גיבוי (`Copy-Item .\logs\security.log .\logs\security.log.bak`)



Lab 1a SOC Dashboard

Cyclic detection with periodic MITRE ATT&CK STIX refresh

Last detector scan: 2026-10-25T15:53:59.932612+00:00
STIX status: Loaded
STIX source: enterprise-attack-mini.json
Techniques loaded: 2
STIX loaded at: 2026-10-25T15:52:24.762282+00:00

Total findings	High severity	Medium severity
2	1	1

Detection Findings

#	Activity	Source IP	MITRE ATT&CK	Tactic	Severity	STIX lookup	Evidence
1	Possible network service discovery	172.18.0.7	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7 against ports 22,80,443,3306
2	Possible brute-force login attempt	172.18.0.5	T1110 - Brute Force	Credential Access	High	Resolved from STIX	3 failed password events were detected from 172.18.0.5.

Raw Security Log

```
2026-07-11T09:00:10 INFO User student logged in successfully from 172.18.0.10
2026-07-11T09:02:11 WARN Failed password for root from 172.18.0.5 port 44231 ssh2
2026-07-11T09:02:14 WARN Failed password for root from 172.18.0.5 port 44232 ssh2
2026-07-11T09:02:18 WARN Failed password for root from 172.18.0.5 port 44233 ssh2
2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7 against ports 22,80,443,3306
2026-07-11T09:07:33 INFO User administrator logged out
```

2. כמות ממצאים ראשונית מתוך לוג הבסיס הנקי (Initial Finding Count)

בטעינה הראשונית של לוג הבסיס הנקי (Baseline) זוהו על ידי מנוע הזיהוי בדיוק **2 ממצאים** (Total findings: 2), בהתאמה מלאה לתוכן הקובץ `output/findings.json` וללוח הבקרה:

- **ממצא אחד ברמת חומרה גבוהה (High severity):** שיוך לטכניקת Brute Force(T1110) עבור כתובת מקור `172.18.0.5`.
- **ממצא אחד ברמת חומרה בינונית (Medium severity):** שיוך לטכניקת Network Service discovery (T1046) עבור כתובת מקור `172.18.0.7`.

שתי שורות הלוג הנוספות התחברות מוצלחת של משתמש student והתנתקות של administrator לא עוררו התרעות מאחר שאינן תואמות לחוקי הזיהוי שהוגדרו בקוד.

3. טבלת ראיות, חוקים, מיפוי MITRE ATT&CK וחוסר ודאות

הטבלה הבאה מנתחת את שני הממצאים המקוריים, את שורות הראיה הגולמיות, את הלוגיקה של חוק הזיהוי, את המיפוי למסגרת MITRE ATT&CK, ואת חוסר הוודאות (Uncertainty) והמגבלות של הכלל:

חוסר ודאות ומגבלות (Uncertainty)	טקטיקה (Tactic)	טכניקת MITRE ATT&CK	חוק זיהוי (Detection Rule)	ראיה גולמית בלוג (Raw Evidence)
1. **חוסר ודאות לגבי כוונה:** הכלל אינו מבדיל בין מתקפת סיסמאות עוינת לבין מנהל מערכת לגיטימי ששכח סיסמה או טעה בהקלדה. 2. **העדר חלון זמן:** הכלל סופר שורות במצטבר ללא הגבלת זמן (Time Window). 3. **תוצאה לא ידועה:** אין בלוג עדות האם הניסיון הצליח בהמשך.	**Credential Access**	**T1110** Brute Force	חיפוש המחרוזת "Failed password" וקיבוץ לפי כתובת IP מקור. כאשר מספר השגיאות לאותה כתובת מגיע ל-3 ומעלה (FAILED_PASSWORD_THRESHOLD = 3), מופקת התרעת High.	שלוש שורות רצופות: • `2026-07-11T09:02:11 WARN Failed password for root from 172.18.0.5 port 44231 ssh2` • `2026-07-11T09:02:14 WARN Failed password for root from 172.18.0.5 port 44232 ssh2` • `2026-07-11T09:02:18 WARN Failed password for root from 172.18.0.5 port 44233 ssh2`
1. **חוסר אימות עצמאי:** ה-detector אינו מנתח מנות רשת (Packets) או חיבורים בפועל, אלא מסתמך באופן עיוור על דיווח טקסטואלי של מערכת חיצונית. 2. **אי-ידיעת לגיטימיות:**	**Discovery**	**T1046** Network Service Discovery	זיהוי מחרוזת טקסטואלית מדויקת "Network scan detected". מציאת המחרוזת מפיקה ישירות התרעת Medium המשויכת	שורת לוג בודדת: • `2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7`

חוסר ודאות ומגבלות (Uncertainty)	טקטיקה (Tactic)	טכניקת MITRE ATT&CK	חוק זיהוי (Detection Rule)	ראיה גולמית בלוג (Raw Evidence)
לא ניתן לדעת אם מדובר בסורק פגיעויות ארגוני מאושר (כמו Nessus/OpenVAS) או בפעילות תוקף. 3. **אי-ידיעת תוצאה:** אין אינדיקציה האם הפורטים שנבדקו היו פתוחים או סגורים.			לכתובת המקור המופיעה בשורה.	`against ports 22,80,443,3306`

4. תוצאות הניסויים המבוקרים (Experiments C1–C4)

בכל הניסויים המבוקרים להלן רכיב הסימולטור היה במצב כבוי (`docker compose stop simulator`) לצורך הבטחת הדירות התוצאות.

ניסוי C1 – בדיקה מתחת לסף (Below the Threshold)

- **השורות ששונו בלוג:** נמחקה שורת כשל אחת מתוך השלוש של `172.18.0.5`, כך שנותרו בקובץ 2 שורות כשל בלבד מכתובת זו.
- **תוצאה צפויה (Prediction):** ממצא T1110 ייעלם מאחר שלא נחצה הסף; ממצא T1046 יישאר; סך הממצאים הכולל יעמוד על 1.
- **תוצאה בפועל (Actual Result):** סך הממצאים עמד על 1 (התרעת T1046 ברמת Medium נותרה; התרעת T1110 ברמת High ירדה ל-0).
- **הסבר טכני:** סף ההתרעה בקוד מוגדר כ-`FAILED_PASSWORD_THRESHOLD = 3`. כאשר הספירה המצטברת עמדה על 2, התנאי הלוגי לא התקיים וההתרעה הוסרה מקובץ הממצאים.

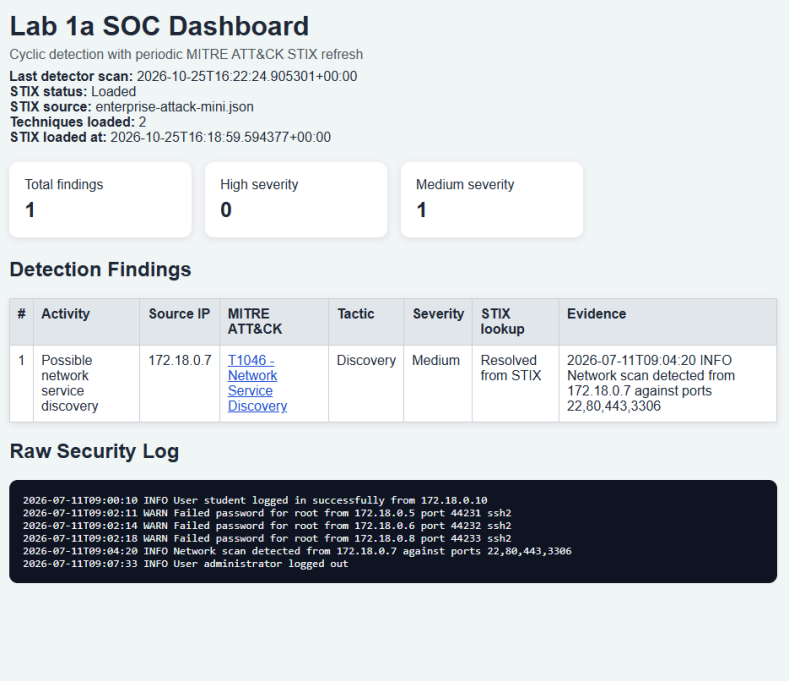
ניסוי C2 – שלושה כשלי התחברות משלוש כתובות IP שונות

- **השורות ששונו בלוג:** הוחזרו 3 שורות כשל, אך לכל שורה הוגדרה כתובת IP מקור שונה:

```
2026-07-11T09:02:11 WARN Failed password for root from
172.18.0.5 port 44231 ssh2
2026-07-11T09:02:14 WARN Failed password for root from
172.18.0.6 port 44232 ssh2
```

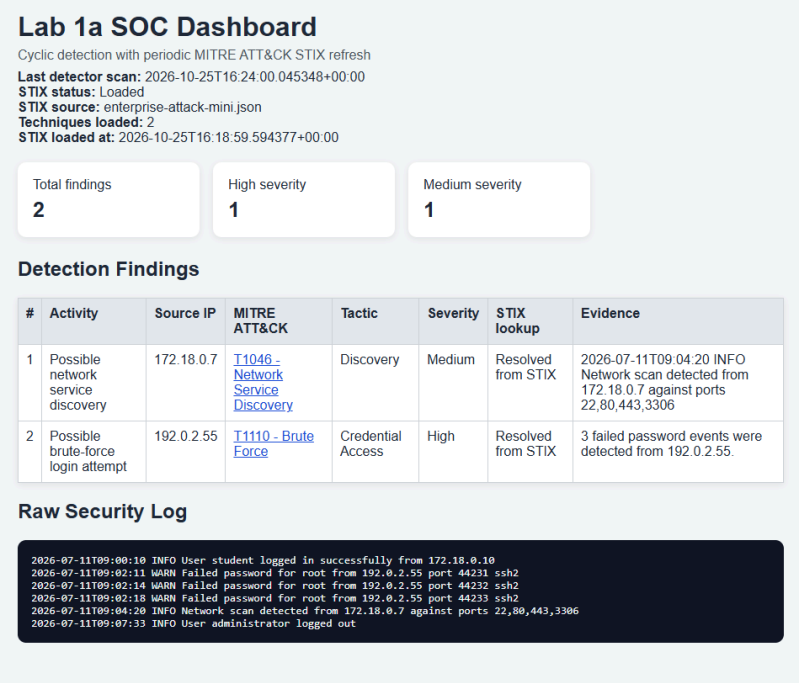
```
2026-07-11T09:02:18 WARN Failed password for root from 172.18.0.8 port 44233 ssh2
```

- **תוצאה צפויה (Prediction):** ממצא T1110 לא יופיע כלל, כיוון שחוק הזיהוי מקבץ אירועים לפי כתובת IP; סך הממצאים: 1 (רק T1046).
- **תוצאה בפועל (Actual Result):** סך הממצאים בלוח הבקרה עמד על 1 (ממצא T1046 ברמת Medium, אפס ממצאי High).
- **הסבר טכני:** מנוע הזיהוי מבצע Group By לפי `source_ip`. כל אחת משלוש הכתובות רשמה כשל בודד בלבד (1 מתוך 3), ולכן אף ישות ברשת לא חצתה את הסף באופן פרטני.



ניסוי C3 – חציית סף מכתובת IP חדשה

- **השורות שנוספו בלוג:** התווספו 3 רשומות כשל רצופות מכתובת חדשה שאינה מתוך הטווח המקורי: `192.0.2.55` (בפורטים 44231, 44232, 44233).
- **תוצאה צפויה (Prediction):** תיווצר התרעת T1110 חדשה המשויכת ל-`192.0.2.55`; סך הממצאים הכולל יעלה ל-2.
- **תוצאה בפועל (Actual Result):** סך הממצאים בלוח הבקרה עלה ל-2 (ממצא High אחד של T1110 מ-`192.0.2.55` וממצא Medium אחד של T1046 מ-`172.18.0.7`).
- **הסבר טכני:** הכתובת החדשה `192.0.2.55` צברה 3 שורות כשל, חצתה את סף ההתרעה בקוד, ומנוע הזיהוי זיהה אותה בסריקה התקופתית והנפיק עבורה רשומת STIX.



Lab 1a SOC Dashboard

Cyclic detection with periodic MITRE ATT&CK STIX refresh

Last detector scan: 2026-10-25T16:24:00.045348+00:00
STIX status: Loaded
STIX source: enterprise-attack-mini.json
Techniques loaded: 2
STIX loaded at: 2026-10-25T16:18:59.594377+00:00

Total findings	High severity	Medium severity
2	1	1

Detection Findings

#	Activity	Source IP	MITRE ATT&CK	Tactic	Severity	STIX lookup	Evidence
1	Possible network service discovery	172.18.0.7	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7 against ports 22,80,443,3306
2	Possible brute-force login attempt	192.0.2.55	T1110 - Brute Force	Credential Access	High	Resolved from STIX	3 failed password events were detected from 192.0.2.55.

Raw Security Log

```
2026-07-11T09:00:10 INFO User student logged in successfully from 172.18.0.10
2026-07-11T09:02:11 WARN Failed password for root from 192.0.2.55 port 44231 ssh2
2026-07-11T09:02:14 WARN Failed password for root from 192.0.2.55 port 44232 ssh2
2026-07-11T09:02:18 WARN Failed password for root from 192.0.2.55 port 44233 ssh2
2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7 against ports 22,80,443,3306
2026-07-11T09:07:33 INFO User administrator logged out
```

ניסוי C4 – הוספת רשומת סריקת רשת שנייה

- **השורות שנוספו בלוג:** נוספה שורת סריקה סינתטית שנייה:
  `2026-10-22T10:02:00Z INFO Network scan detected from 192.0.2.77 against ports 22,80,443`
- **תוצאה צפויה (Prediction):** תיווצר התרעת T1046 נוספת עבור `192.0.2.77`; סך הממצאים יעלה ל-3 (שני Medium ואחד High).
- **תוצאה בפועל (Actual Result):** סך הממצאים עלה ל-3 (שני ממצאי Medium עבור T1046 מכתובות `172.18.0.7` ו-`192.0.2.77`, וממצא High אחד של T1110 מ-`192.0.2.55`).
- **הסבר טכני:** חוק T1046 הוא חוק מבוסס אירוע בודד (ללא סף מספרי). כל הופעה של מחרוזת הזיהוי בלוג מייצרת באופן עצמאי ממצא Network Service Discovery חדש עבור כתובת ה-IP המצוינת ברשומה.



Lab 1a SOC Dashboard

Cyclic detection with periodic MITRE ATT&CK STIX refresh

Last detector scan: 2026-10-25T16:25:00.130785+00:00
STIX status: Loaded
STIX source: enterprise-attack-mini.json
Techniques loaded: 2
STIX loaded at: 2026-10-25T16:18:59.594377+00:00

Total findings	High severity	Medium severity
3	1	2

Detection Findings

#	Activity	Source IP	MITRE ATT&CK	Tactic	Severity	STIX lookup	Evidence
1	Possible network service discovery	172.18.0.7	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7 against ports 22,80,443,3306
2	Possible network service discovery	192.0.2.77	T1046 - Network Service Discovery	Discovery	Medium	Resolved from STIX	2026-10-22T10:02:00Z INFO Network scan detected from 192.0.2.77 against ports 22,80,443
3	Possible brute-force login attempt	192.0.2.55	T1110 - Brute Force	Credential Access	High	Resolved from STIX	3 failed password events were detected from 192.0.2.55.

Raw Security Log

```
2026-07-11T09:00:10 INFO User student logged in successfully from 172.18.0.10
2026-07-11T09:02:11 WARN Failed password for root from 192.0.2.55 port 44231 ssh2
2026-07-11T09:02:14 WARN Failed password for root from 192.0.2.55 port 44232 ssh2
2026-07-11T09:02:18 WARN Failed password for root from 192.0.2.55 port 44233 ssh2
2026-07-11T09:04:20 INFO Network scan detected from 172.18.0.7 against ports 22,80,443,3306
2026-07-11T09:07:33 INFO User administrator logged out
2026-10-22T10:02:00Z INFO Network scan detected from 192.0.2.77 against ports 22,80,443
```

5. תצפית מפעילות הסימולטור (Activity D – Simulator) (Observation)

לאחר השלמת הניסויים המבוקרים, הופעל רכיב הסימולטור הסינתטי באמצעות הפקודה:

```
docker compose --profile simulation up -d
```

ממצאים ותצפיות שנרשמו:

- **הזרמת אירועים דינמית:** הסימולטור החל להוסיף רשומות לוג חדשות לקובץ בקצב של כ-10 שניות.
- **הופעת כתובות IP חדשות:** לאורך הריצה זוהו כתובות IP מגוונות, ובהן: `172.18.0.23`, `172.18.0.21`, `172.18.0.12`, `172.18.0.31`, `172.18.0.32`, `172.18.0.33`, וכן כתובות מקוצרות כמו 22 ו-55.
- **דינמיות בכמות הממצאים:** כמות הממצאים בלוח הבקרה לא נשארה קבועה אלא עלתה באופן רציף לאורך זמן (מספר משתנה), שכן מנוע הזיהוי סורק מחדש את כל אורך הקובץ בכל 5 שניות. חלק מהכתובות צברו 3 שורות כשל ויצרו התרעות T1110 חדשות (כגון 172.18.0.21 ו-172.18.0.23).

- **מסקנה לגבי מהימנות:** הסימולטור מייצר סביבה פחות ניתנת לשחזור (Less Reproducible) ביחס לניסויים הידניים, כיוון שתזמון האירועים והאקראיות אינם מאפשרים בדיקת גבולות מבוקרת (Edge-case testing) של חוקים בודדים.

6. נרטיב אנליסט SOC Narrative

עובדות נצפות (Observed Facts):
במהלך ניתוח לוג האבטחה, זוהו 3 ניסיונות התחברות כושלים בפרוטוקול SSH2 עבור חשבון root מכתובת `172.18.0.5` IP בתוך מרווח זמן של 7 שניות (בין השעות 09:02:11 ל-09:02:18). שתי דקות לאחר מכן (09:04:20), נרשם דיווח מערכת על סריקת פורטים (22, 80, 443, 3306) שמקורה בכתובת `172.18.0.7` IP. מנוע הזיהוי סיווג אירועים אלו כטכניקות MITRE ATT&CK T1110 ו-T1046 בהתאמה.
פרשנות והערכות (Interpretations & Hypotheses):
פעילות זו תואמת דפוס התנהגות של שלבי איסוף מידע (Reconnaissance) וניסיון השגת גישה (Credential Access). עם זאת, בהתבסס על הראיות הקיימות בלבד, לא ניתן לאמת כוונת זדון ודאית; ייתכן שמדובר בסריקת תשתית ארגונית שגרתית ובשגיאת הזדהות של משתמש מורשה. בנוסף, לא נצפתה עדות לפריצה מוצלחת או להשגת אחיזה במערכת. מומלץ לבצע מעקב רציף והצלבת לוגים נוספים.

7. סיכום, איפוס וניקוי הסביבה (Cleanup)

בסיום הפעילות שוחזר קובץ הלוג המקורי מתוך הגיבוי שנוצר בתחילת העבודה:

```
Copy-Item .\logs\security.log.bak .\logs\security.log -Force
```

המכולות של סביבת המעבדה והסימולטור כובו והוסרו לחלוטין באמצעות:

```
docker compose --profile simulation down
```